CYBERSECURITY

Basic Pentesting 2

Professional Penetration Testing Write-up

Target IP	10.10.10.5	Attacker IP	10.10.10.3
Platform	TryHackMe / CTF	Difficulty	Easy / Intermediate

Assessment Summary
This report documents the reconnaissance, enumeration, initial access, lateral movement, credential recovery, and privilege escalation performed against the Basic Pentesting 2 lab environment.

Prepared for educational / CTF lab submission

Executive Summary

The assessment began with full TCP port discovery and service enumeration using `nmap`. Multiple exposed services were identified, including FTP, SSH, HTTP, SMB, and Tomcat.

Web enumeration revealed a `/development/` directory, while SMB enumeration exposed valid usernames. A password attack against SSH resulted in initial access as `jan`. From there, a readable SSH private key belonging to kay was recovered and its passphrase was cracked. Finally, unrestricted sudo privileges allowed escalation to root.

Attack Path	Nmap → Web Enumeration → SMB User Discovery → SSH Access as jan → Kay SSH Key → Passphrase Recovery → SSH as kay → sudo → root

1. Reconnaissance

A comprehensive TCP scan was performed to identify exposed services and determine the available attack surface on the target.

```
sudo nmap -sS -sV -p- -n 10.10.10.5
```

Open services identified:

- 21/tcp — FTP
- 22/tcp — SSH
- 80/tcp — HTTP / Apache
- 445/tcp — SMB / Samba
- 8009/tcp and 8080/tcp — Apache Tomcat

2. Web Enumeration — Port 80

Directory fuzzing was performed against the HTTP service using `gobuster` to identify hidden or unlinked resources.

```
gobuster dir -u http://10.10.10.5 -w /usr/share/wordlists/dirb/common.txt
```

Finding	The `/development/` directory was discovered. Additional vulnerability-oriented inspection was performed using `nikto`.

3. SMB Enumeration & User Discovery — Port 445

The SMB service was enumerated with `enum4linux` to identify information exposed by the Samba configuration, including valid local usernames.

```
enum4linux 10.10.10.5
```

Discovered Users	jan and kay

4. SSH Brute-Forcing & Initial Foothold

A local users list containing the discovered usernames was used with `medusa` to perform a dictionary attack against SSH using the `rockyou.txt` wordlist.

```
medusa -U users.txt -P /usr/share/wordlists/rockyou.txt -h 10.10.10.5 -M ssh
```

Credentials	Username: `jan` Password: `armando`

The recovered credentials provided SSH access to the target as `jan`.

```
ssh jan@10.10.10.5
```

5. Lateral Movement — Recovering Kay's SSH Key

After obtaining a shell as `jan`, the home directory of kay was inspected. The SSH configuration directory contained a readable private RSA key.

```
ls -la /home/kay/.ssh
```

The `id_rsa` file was copied to the attacker machine. Its permissions were restricted before further processing:

```
chmod 600 id_rsa
```

6. SSH Key Passphrase Recovery

The recovered private key required a passphrase. The key was converted into a format compatible with John the Ripper using `ssh2john`, followed by a dictionary attack with `rockyou.txt`.

```
ssh2john id_rsa > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Recovered Passphrase	beeswax

The recovered passphrase enabled SSH authentication as kay.

```
ssh -i id_rsa kay@10.10.10.5
```

Inside Kay's home directory, a backup file named `pass.bak` was discovered containing a plaintext password that followed the lab's password-policy theme.

Recovered Password	`heresareallystrongpasswordthatfollowsthepasswordpolicy$$`

7. Privilege Escalation to Root

The sudo configuration was checked to determine whether the kay account had any delegated administrative privileges.

```
sudo -l
```

Sudo Result	`(ALL : ALL) ALL` — Kay can execute commands as any user, including root.

A root shell was then obtained with:

```
sudo su
```

Administrative access was verified using `whoami`:

```
whoami
# root
```

Final Access	Root-level access successfully obtained on the target machine.

8. Attack Chain Summary

Phase	Technique / Action	Result
1	Nmap reconnaissance	Identified exposed services
2	Gobuster web enumeration	Discovered /development/
3	SMB enumeration	Discovered jan and kay
4	Medusa against SSH	Obtained jan credentials
5	SSH key discovery	Recovered kay's id_rsa
6	John the Ripper	Recovered key passphrase
7	SSH as kay	Obtained user-level access
8	sudo -l / sudo su	Escalated to root

9. Key Security Observations

- Multiple network services were exposed, increasing the attack surface.
- SMB enumeration disclosed valid local usernames.

- SSH accepted a weakly guessable credential for the discovered user.
- A private SSH key was readable by an unintended account.
- The SSH private key was protected by a passphrase that was recoverable through dictionary cracking.
- Sensitive credentials were stored in plaintext inside a backup file.
- The kay account had unrestricted sudo privileges, enabling immediate root escalation.